INFORME FORMAL DE AUDITORÍA BASH

Seguridad de la API REST del Portal Vial IMSJ

Proyecto	Proyecto IMSJ - Portal Vial
Fecha de ejecución	21 de octubre de 2026 (UTC registrada por el script)
Objetivo autorizado	http://127.0.0.1:8000 - entorno local Docker
Herramienta principal	backend/tests/security_api.sh con Bash y curl
Versión documental	1.0 - evidencia de cierre técnico
Identificación del código	Rama main; base Git 5f15b3b; snapshot local identificado además mediante hashes SHA-256

Resultado de aceptación: 43 pruebas aprobadas, 0 fallidas, 0 omitidas y código de salida 0.

1. Resumen ejecutivo

Se ejecutó una auditoría automatizada de seguridad sobre la API REST del Proyecto IMSJ en un entorno local expresamente autorizado. La validación combinó controles sin autenticación, sesiones válidas e inválidas, perfiles PUBLICO_GENERAL, PERSONAL_IMSJ y DIRECTORA, datos descartables y casos negativos diseñados para confirmar que la API rechaza operaciones inseguras de forma controlada.

43	0	0	0
Aprobadas	Fallidas	Omitidas	Código de salida

1.1 Objetivo

Obtener evidencia reproducible de que los controles principales de la API funcionan ante solicitudes válidas y maliciosas controladas, y que una ejecución incompleta o con fallos produce un código distinto de cero.

1.2 Alcance y límites

Incluido	Fuera de alcance
API local en 127.0.0.1:8000; autenticación y sesiones; autorización por rol; CORS; cabeceras; archivos; rutas privadas; SQLi/XSS; rate limiting; IDOR de reservas; limpieza de datos.	Infraestructura productiva, HTTPS público, ingeniería social, denegación de servicio sostenida, dispositivos de usuarios y servicios de terceros.

Todas las cédulas visibles en las capturas son identificadores ficticios de prueba. Las contraseñas se introdujeron de forma oculta y no se conservaron en el informe.

2. Metodología y controles

El script realiza peticiones HTTP con curl, compara el código obtenido con el esperado, inspecciona respuestas y encabezados, cuenta resultados y finaliza con estado no cero ante una falla. En modo estricto también falla si queda una prueba omitida. Las operaciones de escritura se limitaron a registros descartables eliminados al finalizar.

Área	Comprobaciones principales	Criterio de aceptación
Disponibilidad	API y healthcheck	HTTP 200 y estado ok
Cabeceras	nosniff, caché, anti-clickjacking, CSP y Server	Controles presentes; sin versión exacta
Autenticación	Sin token, token inválido, válido, revocado y expirado	401 para sesiones no válidas; 200 para sesión válida
Autorización	Panel por rol, aprobación y reserva ajena	403 por rol insuficiente; 404 para recurso ajeno
Entradas	JSON inválido, SQLi y XSS controlados	400/422; sin 500, eco de payload ni ejecución
Archivos	PHP presentado como PDF	422 y ausencia de ejecución
CORS	Origen permitido y origen ajeno	204 permitido; 403 ajeno; origen único
Exposición	.env, config.php, SQL y traversal	404 sin contenido privado
Abuso	Intentos repetidos de login	429 dentro del límite configurado

2.1 Preparación controlada

- Objetivo limitado a la instancia local autorizada; no se realizaron pruebas contra sistemas externos.
- Credenciales solicitadas interactivamente y contraseña oculta en terminal.
- FAQ, usuarios, tokens, franja y reserva creados exclusivamente para comprobar permisos y propiedad.
- Los registros descartables se eliminaron y se verificó que no permanecieran usuarios ni franjas de la preparación final.
- El modo estricto IMSJ_SECURITY_REQUIRE_FULL=1 exigió cero omisiones para aceptar la ejecución final.

3. Resultados y trazabilidad

Ejecución	Rol / propósito	Aprobadas	Fallidas	Omitidas	Salida	Interpretación
security-api-publico.txt	PUBLICO_GENERAL	32	0	4	0	Cobertura del ciudadano; omisiones esperadas por rol
security-api-directora.txt	DIRECTORA	37	0	3	0	Carga maliciosa y 429 confirmados
security-api-personal.txt	PERSONAL_IMSJ	35	0	3	0	Flujo descartable y 403 de aprobación
security-api-final.txt	Aceptación estricta	43	0	0	0	Cobertura completa; resultado final válido

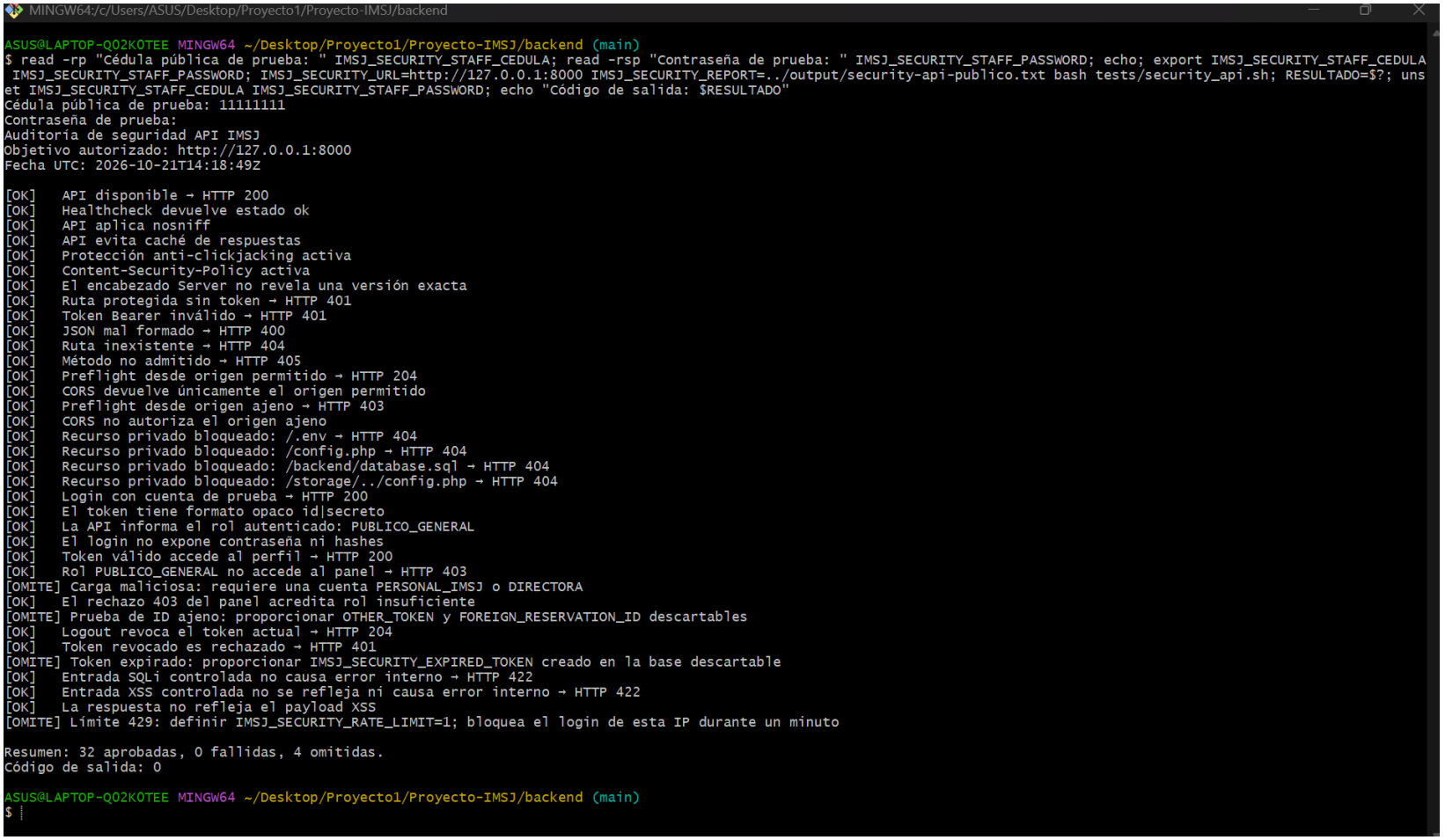
3.1 Interpretación

- No se confirmó ninguna falla de seguridad dentro del alcance automatizado de la ejecución estricta final.
- La respuesta 404 ante una reserva de otro usuario evita revelar su existencia y bloquea la cancelación ajena.
- Los tokens revocado y expirado fueron rechazados con 401; el token válido accedió al perfil con 200.
- El archivo PHP disfrazado de PDF fue rechazado con 422, validando que la extensión declarada no basta para aceptar una carga.
- La cuenta PERSONAL_IMSJ pudo preparar contenido, pero recibió 403 al intentar una acción reservada a DIRECTORA.
- El quinto intento controlado activó 429, confirmando el límite de solicitudes de autenticación.

3.2 Incidencia de ejecución no atribuible a la API

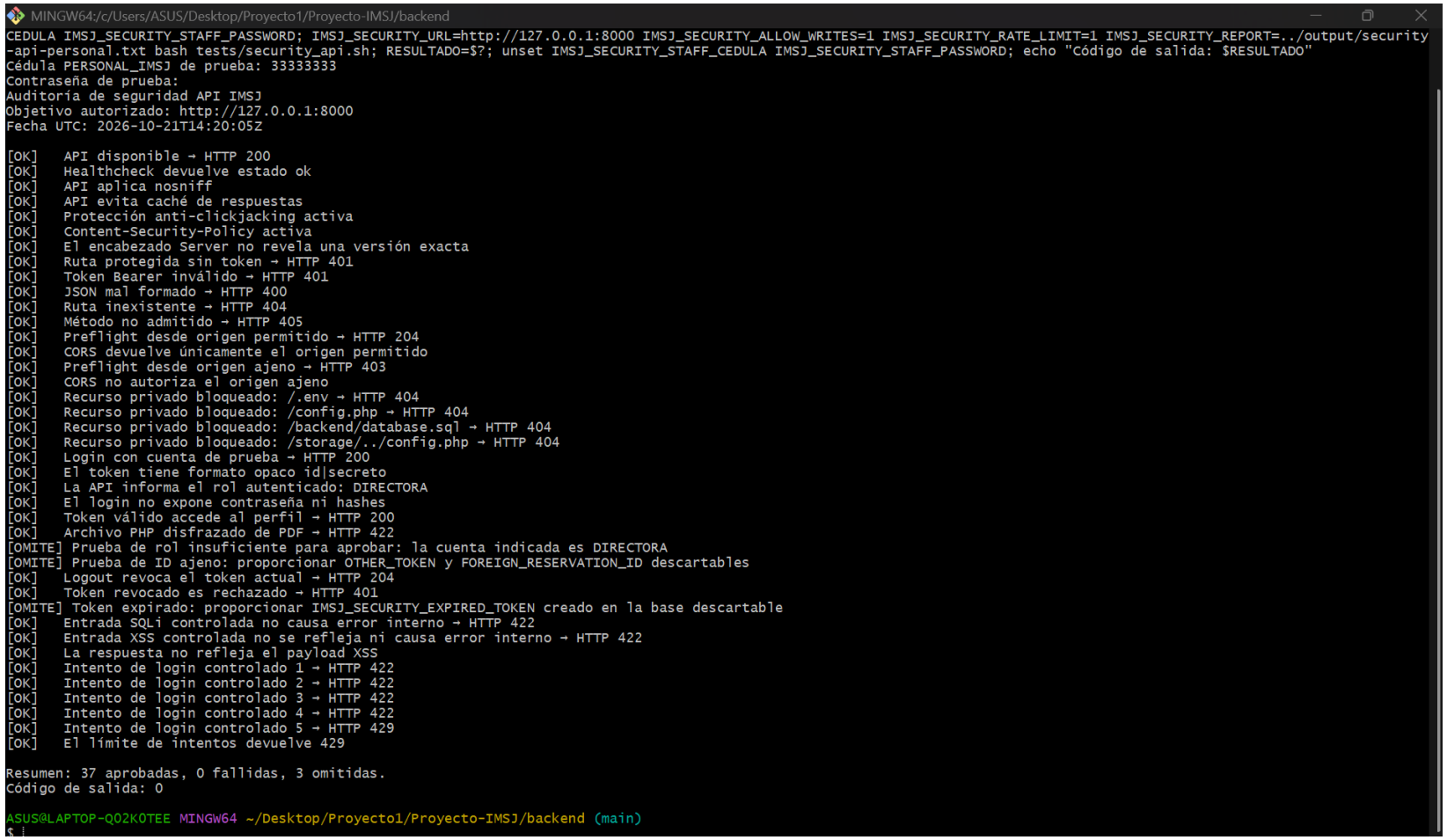
Durante la preparación de la evidencia completa, una primera cadena de consola no separó correctamente tres identificadores devueltos por MySQL. El modo estricto detectó la omisión del caso IDOR y terminó con código 2. Se corrigió el separador de la preparación, se recrearon los datos descartables y se repitió toda la auditoría. La aceptación se basa exclusivamente en la repetición final 43/0/0 con código 0.

Evidencia 1 - Perfil PUBLICO_GENERAL



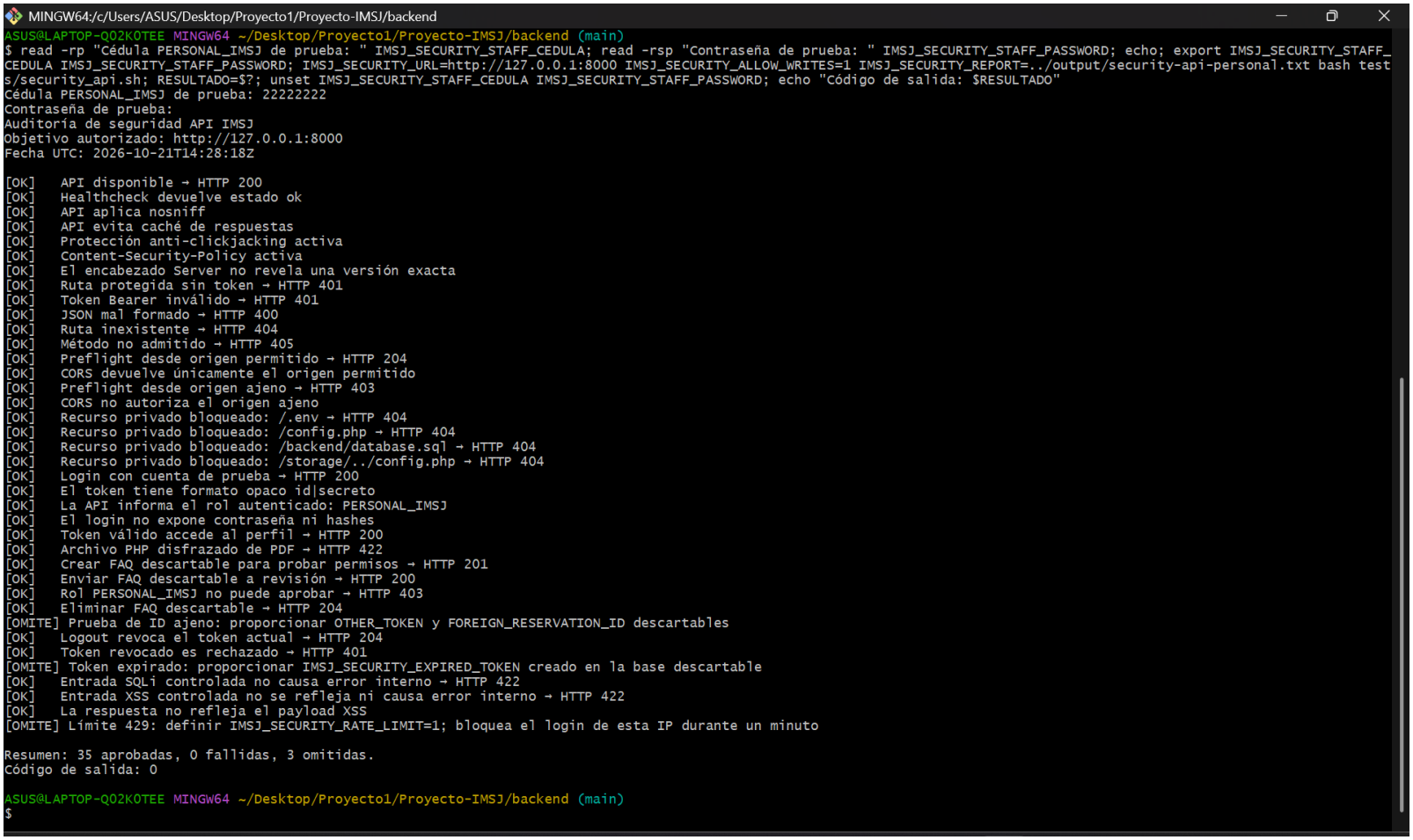
Ejecución autenticada con rol ciudadano: 32 pruebas aprobadas, 0 fallidas y salida 0. Los casos omitidos corresponden a controles que requieren otro rol o preparación específica.

Evidencia 2 - Perfil DIRECTORA



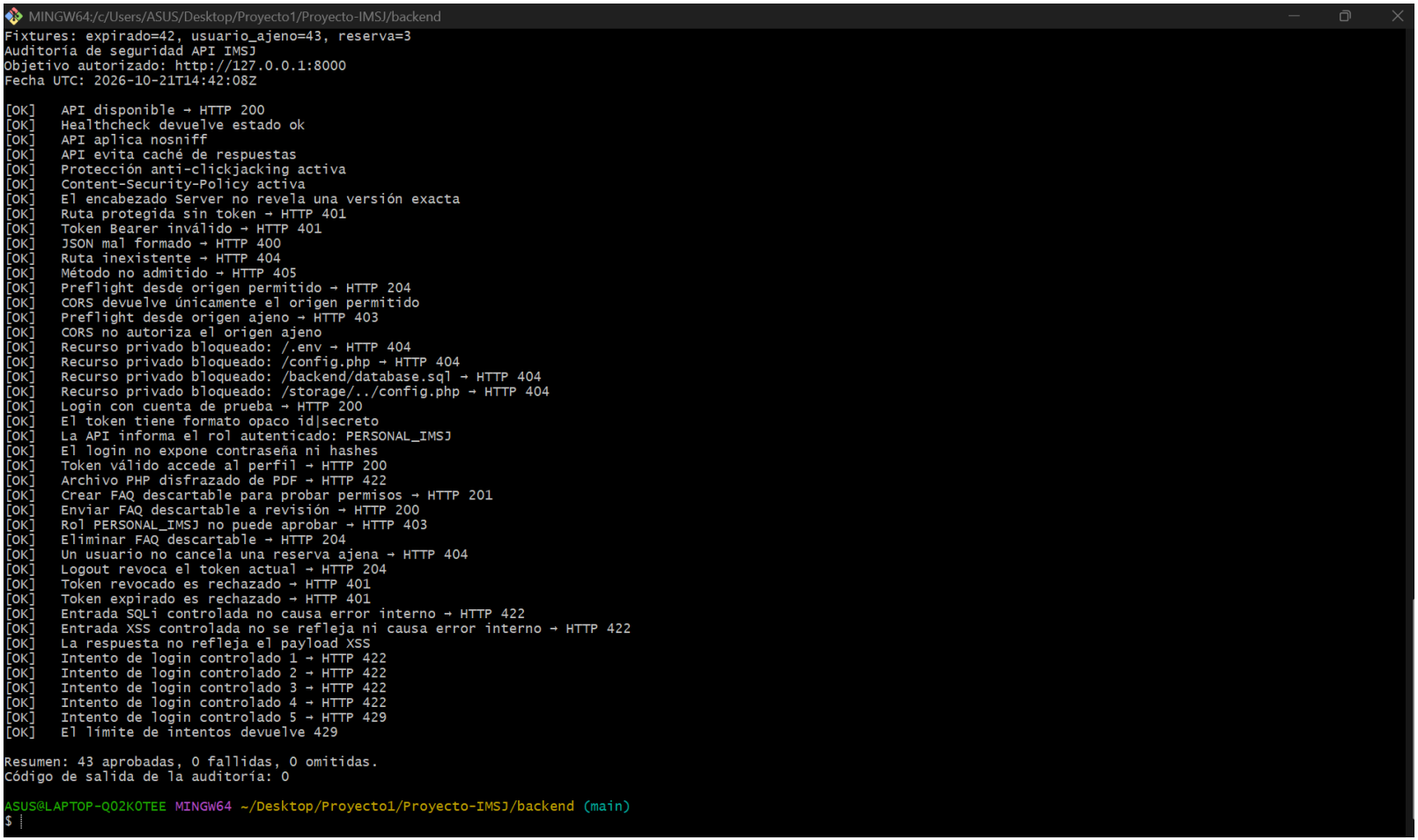
Ejecución con rol DIRECTORA: 37 pruebas aprobadas, 0 fallidas y salida 0. Se observa el rechazo de un archivo PHP presentado como PDF y el límite HTTP 429.

Evidencia 3 - Perfil PERSONAL_IMSJ



Ejecución con rol PERSONAL_IMSJ: 35 pruebas aprobadas, 0 fallidas y salida 0. Incluye creación y eliminación de una FAQ descartable y rechazo 403 al intentar aprobarla.

Evidencia 4 - Ejecución estricta final



Cierre de aceptación: 43 pruebas aprobadas, 0 fallidas, 0 omitidas y código de salida 0. Incluye token expirado, token revocado, reserva ajena, carga maliciosa y límite de intentos.

4. Integridad de la evidencia

Artefacto	SHA-256
backend/tests/security_api.sh	24f4854e64186eea009f900368bfd8f8fd2d265e399e53ed5a3cb8aed544714d
output/security-api-final.txt	e9e884a49368782da1c4e08b346b97291da03549d17b81f8c7504e507ae7798e

5. Limitaciones

- El informe documenta una ejecución local; no acredita la configuración TLS/HTTPS de un despliegue productivo.
- Las pruebas automáticas reducen riesgo, pero no demuestran ausencia absoluta de vulnerabilidades.
- Las ejecuciones parciales por rol contienen omisiones previstas; la conclusión técnica se apoya en la ejecución estricta final sin omisiones.
- El snapshot evaluado parte del commit 5f15b3b e incluye cambios locales; antes de la entrega debe asociarse esta evidencia al commit o tag definitivo.

6. Conclusión

La auditoría Bash de seguridad de la API REST IMSJ cumple su criterio técnico de cierre. La ejecución final verificó todos los controles programados sin fallas ni omisiones y produjo código de salida 0. Las respuestas observadas fueron coherentes con la política de autenticación, autorización, validación de entradas, protección de archivos, CORS y limitación de intentos.

DICTAMEN: APROBADO dentro del alcance local autorizado y sujeto a vincular la evidencia con la versión final entregada.

Elaborado por	Revisado por	Fecha de aprobación
Equipo Proyecto IMSJ	_____	_____